Penetration Testing
Une introduction pratique au piratage

par Georgia Weidman (No Starch Press, 2014)

Résumé complet du livre

Aperçu chapitre par chapitre avec des outils, des techniques et des points clés à retenir

Préparé comme compagnon de lecture – et non comme substitut au texte intégral.

À propos de ce résumé

Ce document résume les 21 chapitres (chapitre 0 au chapitre 20) de Penetration Testing : A Hands-On Introduction to Hacking de Georgia Weidman. Le livre enseigne les tests d'intrusion de bout en bout via un laboratoire pratique construit autour de machines virtuelles (une boîte d'attaque Kali Linux et des cibles Windows XP, Windows 7 et Ubuntu), en suivant les phases standard d'un test d'intrusion : pré-engagement, collecte d'informations, modélisation des menaces, analyse des vulnérabilités, exploitation, post-exploitation et reporting.

Chaque section de chapitre ci-dessous comprend : un bref résumé, les techniques clés couvertes et un encadré répertoriant les outils spécifiques introduits ou utilisés dans ce chapitre. Les outils qui apparaissent pour la première fois dans le livre sont marqués en orange la première fois qu'ils apparaissent.

Structure du livre (5 parties)

- Partie I — Les bases (Ch. 1 à 4) : configuration du laboratoire, Kali Linux, scripts, principes fondamentaux de Metasploit.
- Partie II — Évaluations (Ch. 5–7) : collecte d'informations, découverte de vulnérabilités, capture de trafic.
- Partie III — Attaques (Ch. 8 à 15) : exploitation, mots de passe, attaques côté client, ingénierie sociale, évasion antivirus, post-exploitation, tests d'applications Web, attaques sans fil.
- Partie IV — Développement d'exploits (Ch. 16-19) : débordements de tampon sous Linux et Windows, écrasements SEH, fuzzing et écriture de modules Metasploit.
- Partie V — Mobile Hacking (Ch. 20) : le Smartphone Pentest Framework (SPF).

Chapitre d'introduction

Chapitre 0 : Introduction aux tests de pénétration

Le chapitre 0 définit les tests d'intrusion comme allant au-delà d'une analyse de vulnérabilité : les testeurs détectent les faiblesses et les exploitent pour montrer leur impact réel, en simulant ce qu'un attaquant réel pourrait réaliser.

Il présente les six phases classiques d'un pentest qui structurent le reste de l'ouvrage : le pré-engagement (cadrage, règles d'engagement, autorisation/carte "sortir de prison gratuitement", conditions de paiement), la collecte d'informations (OSINT), la modélisation des menaces, l'analyse de vulnérabilité, l'exploitation, la post-exploitation et le reporting (résumé exécutif + rapport technique).

Techniques et points clés

- Distingue un pentest (exploiter pour prouver l'impact) d'une évaluation de vulnérabilité (identifier uniquement).
- Le pré-engagement doit définir la portée, la fenêtre de test, les contacts, l'autorisation légale et les termes de la NDA.
- Un bon rapport comporte un résumé (contexte, posture, profil de risque, recommandations, feuille de route) et un rapport technique (résultats détaillés par phase).
- Fait référence à la norme PTES (Penetration Testing Execution Standard) et au NIST SP 800-115.

Outils utilisés dans ce chapitre

PTES methodology	NIST SP 800-115 guide

Partie I — Les bases

Chapitre 1 : Configuration de votre laboratoire virtuel

Un chapitre entièrement pratique : le lecteur construit le laboratoire utilisé tout au long du livre. Il explique l'installation de VMware (Player/Fusion/Workstation), le téléchargement et la personnalisation d'une machine virtuelle d'attaque Kali Linux et la configuration d'un réseau virtuel isolé réservé à l'hôte afin que les attaques restent contenues.

Il construit ensuite trois cibles vulnérables : une boîte Windows XP SP3 chargée de logiciels tiers vulnérables, une boîte Windows 7 et une boîte Ubuntu 8.10 - chacune avec des adresses IP statiques, des comptes de test et (pour Windows XP) des outils de débogage pour les chapitres ultérieurs de développement d'exploits.

Techniques et points clés

- Kali Linux (successeur de BackTrack) est la plateforme d'attaque de tout le livre.
- Un réseau virtuel isolé/hôte uniquement empêche les attaques de laboratoire de se propager sur les réseaux réels.
- La cible Windows XP est délibérément chargée d'applications vulnérables pour la pratique de l'exploitation.
- Le plugin Immunity Debugger + Mona est installé sur Windows XP pour les chapitres ultérieurs sur le buffer overflow.

Outils utilisés dans ce chapitre

VMware (Player/Fusion/Workstation) Mona.py plugin	Kali Linux Android emulator / SDK	Nessus (installed here, used in Ch.6) Smartphone Pentest Framework (preview install)	Immunity Debugger

★ Nouveaux dans ce chapitre : VMware, Kali Linux, Immunity Debugger, Mona.py

---

Chapitre 2 : Utiliser Kali Linux

Une introduction à Linux/ligne de commande destinée aux lecteurs ayant peu d'expérience Linux. Couvre le système de fichiers, la navigation, les pages de manuel, la gestion des privilèges utilisateur (useradd, sudoers, sudo), les autorisations de fichiers, l'édition de texte (vi) et les utilitaires de base de manipulation de données.

Présente également la gestion des packages, la gestion des processus/services, les commandes réseau de base, Netcat en tant qu'outil TCP/IP polyvalent et l'automatisation des tâches avec cron.

Techniques et points clés

- grep, sed et awk sont présentés comme le trio principal de traitement de texte pour l'analyse des résultats.
- Netcat (nc) - ouvrir un écouteur de shell et pousser un shell inversé - est couvert comme une compétence fondamentale réutilisée dans les chapitres d'exploitation ultérieurs.
- Les tâches cron sont introduites pour automatiser les tâches récurrentes (et réutilisées plus tard pour la persistance Linux).

Outils utilisés dans ce chapitre

Linux shell / Bash grep Netcat (nc)	man pages sed cron	useradd / sudo awk	vi editor apt / package manager

★ Nouveaux dans ce chapitre : Netcat (nc)

Chapitre 3 : Programmation

Une introduction courte et pratique aux scripts pour les pentesters dans trois langages : Bash, Python et C. L'objectif est d'écrire de petits assistants d'automatisation (par exemple, des pings de script/vérifications de ports) plutôt qu'une ingénierie logicielle complète.

Couvre les variables, les instructions if et les boucles for en Bash et Python, l'ouverture d'un socket TCP en Python et la compilation d'un simple programme C — compétences réutilisées plus tard pour écrire des exploits et porter du code d'exploit public.

Techniques et points clés

- Scripts Bash : balayages ping, instructions if, boucles for pour automatiser les tâches de reconnaissance.
- Scripts Python : connexions de socket et conditions - le langage utilisé pour le prototypage d'exploits plus loin dans le livre (Partie IV).
- La compilation C de base est introduite car de nombreuses cibles d'exploit et concepts de shellcode sont basés sur C.

Outils utilisés dans ce chapitre

Bash	Python	GCC / C compiler

★ Nouveaux dans ce chapitre : Python scripting

Chapitre 4 : Utilisation du framework Metasploit

Première exploitation pratique du lecteur : utilisation de la vulnérabilité Windows SMB MS08-067 contre la cible XP via msfconsole. Couvre la recherche/sélection de modules, les options de configuration (RHOST, RPORT, SMBPIPE, cible), le choix des charges utiles et la différence entre les shells de liaison et inversés.

Présente Meterpreter en tant que payload post-exploitation avancée de Metasploit, l'ancienne interface monoligne msfcli, msfvenom pour créer des charges utiles autonomes, le module multi/gestionnaire pour intercepter les rappels et exécuter un module auxiliaire (non exploitable).

Techniques et points clés

- Workflow de base de msfconsole : rechercher → utiliser → afficher les options → définir RHOST/payload → exploiter.
- msfvenom a remplacé l'ancien combo msfpayload/msfencode pour la génération de payload autonome.
- multi/handler est l'écouteur générique utilisé chaque fois qu'une payload est livrée en dehors d'un module auto-exploité (téléchargement Web, pièce jointe à un e-mail, etc.).
- Les modules auxiliaires (par exemple, scanner/smb/pipe_auditor) effectuent des tâches d'analyse/utilitaires, pas d'exploitation.

Outils utilisés dans ce chapitre

Metasploit Framework (msfconsole) multi/handler module	Meterpreter Metasploit auxiliary modules	msfcli (legacy) msfupdate	msfvenom

★ Nouveaux dans ce chapitre : Metasploit Framework, Meterpreter, msfvenom

Partie II — Évaluations

Chapitre 5 : Collecte d'informations

Ouvre le test d'intrusion simulé de la partie II. Couvre la collecte passive de renseignements open source (OSINT) – Netcraft, Whois, reconnaissance DNS (nslookup, transferts de zone) et recherche des adresses e-mail des employés – puis introduit theHarvester et Maltego pour la corrélation OSINT automatisée.

Passage à la reconnaissance active : concepts d'analyse manuelle des ports (prise de contact TCP, capture de bannière avec Netcat) suivis d'une analyse automatisée avec Nmap (analyse SYN, détection de version, analyse UDP).

Techniques et points clés

- OSINT est gratuit, passif et à faible risque : il doit précéder toute analyse active.
- theHarvester automatise la recherche des moteurs de recherche/serveurs PGP pour les e-mails et les hôtes.
- Maltego cartographie visuellement les relations entre les domaines, les personnes et l'infrastructure.
- Indicateurs Nmap couverts : -sS (analyse SYN), -sV (détection de version), -sU (analyse UDP), -oA (sortie de tous les formats).

Outils utilisés dans ce chapitre

Netcraft Maltego	Whois Netcat (banner grabbing)	nslookup / host (DNS recon) Nmap	theHarvester

★ Nouveaux dans ce chapitre : theHarvester, Maltego, Nmap

Chapitre 6 : Recherche de vulnérabilités

Couvre la phase d'analyse des vulnérabilités : transformer les résultats Nmap en vulnérabilités candidates, exécuter le scanner de vulnérabilités Nessus (politiques, analyse, interprétation des classements, exportation des résultats) et utiliser le moteur de script Nmap (NSE) pour des vérifications ciblées.

Couvre également les propres modules d'analyse et de vérification des exploits de Metasploit, l'analyse des applications Web avec Nikto, la vérification des informations d'identification par défaut sur XAMPP/WebDAV et l'analyse manuelle, par exemple en utilisant la commande VRFY SMTP pour énumérer les noms d'utilisateur valides.

Techniques et points clés

- Les scanners de vulnérabilités (Nessus) complètent mais ne remplacent pas la pensée critique manuelle.
- Les scripts NSE (par exemple, nfs-ls) étendent Nmap pour sonder des protocoles/services spécifiques.
- exploiter les fonctions "check" dans Metasploit tester l'exploitabilité sans déclencher l'exploit complet.
- Au final, plusieurs vulnérabilités concrètes sont répertoriées sur les cibles XP, Linux et Win7 (MS08-067, phpMyAdmin, crédits par défaut XAMPP/WebDAV, mauvaise configuration NFS, porte dérobée vsftpd 2.3.4, etc.).

Outils utilisés dans ce chapitre

Nessus cadaver (WebDAV client)	Nmap Scripting Engine (NSE) VRFY/SMTP enumeration	Metasploit scanner/check modules	Nikto

★ Nouveaux dans ce chapitre : Nessus (used), Nikto

Chapitre 7 : Capturer le trafic

Se concentre sur le reniflage et la manipulation du trafic réseau. Présente Wireshark pour capturer, filtrer et suivre les flux TCP, puis couvre l'empoisonnement du cache ARP (concept, transfert IP et outil arpspoof) pour rediriger le trafic réseau commuté via la machine attaquante, y compris l'usurpation d'identité de la passerelle par défaut.

S'étend à l'empoisonnement du cache DNS avec dnsspoof, aux attaques SSL man-in-the-middle utilisant Ettercap et à la défaite des redirections HTTPS avec SSLstrip.

Techniques et points clés

- L'empoisonnement ARP exploite le manque d'authentification dans ARP pour se positionner comme un homme du milieu.
- dnsspoof redirige les victimes vers des sites contrôlés par des attaquants en falsifiant des réponses DNS.

- Ettercap automatise SSL MITM ; les utilisateurs voient toujours un avertissement de certificat à moins qu'il ne soit combiné avec SSLstrip.
- SSLstrip rétrograde les liens HTTPS vers HTTP de manière transparente, en capturant les informations d'identification en texte brut.

Outils utilisés dans ce chapitre

Wireshark SSLstrip	arpspoof iptables (traffic redirection)	dnsspoof	Ettercap

★ Nouveaux dans ce chapitre : Wireshark, arpspoof, dnsspoof, Ettercap, SSLstrip

Partie III — Attaques

Chapitre 8 : Exploitation

Convertit les vulnérabilités trouvées dans Ch. 5 à 7 en de véritables compromis. Revisite MS08-067 avec Meterpreter, exploite les informations d'identification WebDAV/XAMPP par défaut pour télécharger une payload PHP Meterpreter et abuse d'un panneau phpMyAdmin ouvert pour écrire des fichiers et un téléchargement TFTP.

Couvre le téléchargement de fichiers sensibles (configurations, le SAM Windows), l'exploitation d'un buffer overflow dans un logiciel tiers, l'exploitation d'applications Web tierces vulnérables (TikiWiki), l'exploitation d'un service de porte dérobée (vsftpd 2.3.4) et l'abus d'un partage NFS ouvert/mal configuré pour installer une clé SSH pour une connexion sans mot de passe.

Techniques et points clés

- Affiche plusieurs chemins d'exploitation au-delà de « il suffit d'exécuter Metasploit » : téléchargement manuel de fichiers, abus du panneau de base de données, transfert TFTP et abus de confiance NFS.
- Démontre le téléchargement de charges utiles msfvenom personnalisées (PHP Meterpreter) et leur capture avec le gestionnaire.
- Les logiciels open source dérobés (vsftpd) sont traités comme une catégorie d’exploitation dans le monde réel.
- La mauvaise configuration NFS + l'injection de clé SSH est une chaîne d'attaque non Metasploit et purement manuelle.

Outils utilisés dans ce chapitre

Metasploit (ms08_067_netapi) TFTP (atftpd)	msfvenom (PHP Meterpreter) TikiWiki exploit module	cadaver (WebDAV) NFS mount + ssh-keygen	phpMyAdmin abuse vsftpd backdoor

Chapitre 9 : Attaques de mot de passe

Couvre les attaques de mots de passe en ligne et hors ligne. En ligne : création de listes de mots personnalisées avec CeWL et Crunch, puis services de force brute avec Hydra.

Hors ligne : vidage des hachages de mots de passe Windows (hashdump Meterpreter, bkhive/samdump2 à partir d'un disque monté), explique les faiblesses du hachage LM vs NTLM, cracking avec John the Ripper (hachages Windows et Linux, mots de passe des fichiers de configuration), tables arc-en-ciel, services de cracking cloud et vidage des mots de passe en clair de la mémoire avec Windows Credential Editor (WCE).

Techniques et points clés

- Les hachages LM ne sont pas sensibles à la casse et sont divisés en deux moitiés de 7 caractères – bien plus faibles que NTLM.
- John the Ripper prend en charge les formats de hachage Windows (LM/NTLM) et Linux (fichier fantôme).
- Les tables arc-en-ciel échangent de l'espace disque contre de la vitesse de craquage via des chaînes de hachage précalculées.
- WCE extrait les informations d'identification en texte brut directement de la mémoire sur les systèmes Windows actifs.

Outils utilisés dans ce chapitre

CeWL bkhive Windows Credential Editor (WCE)	Crunch samdump2	Hydra John the Ripper	Meterpreter hashdump Rainbow tables / RainbowCrack

★ Nouveaux dans ce chapitre : Hydra, John the Ripper, WCE

Chapitre 10 : Exploitation côté client

Passage des attaques côté serveur aux attaques côté client : logiciels que l'utilisateur doit ouvrir. Couvre le contournement des filtres de sortie avec des charges utiles tous ports et HTTP/S Metasploit, puis une chaîne d'exploitation complète du navigateur (MS10-002 Aurora), y compris la migration des sessions et AutoRunScript.

Couvre les exploits PDF malveillants (Adobe utilprintf, EXE intégré au PDF), un exploit Java alors nul, le module automatisé browser_autopwn et un exploit côté client basé sur Winamp.

Techniques et points clés

- Les attaques côté client nécessitent une interaction de l'utilisateur (ouverture d'un fichier/d'une page) — le point faible est l'humain, préfigurant l'ingénierie sociale du Ch.11.
- browser_autopwn déclenche automatiquement de nombreux exploits de navigateur en fonction de l'empreinte digitale du visiteur.
- Souligne à quel point les systèmes entièrement corrigés peuvent toujours être compromis via des bogues logiciels clients Zero Day.
- La migration de session (run migrate / AutoRunScript) permet de stabiliser l'accès après exploitation.

Outils utilisés dans ce chapitre

Metasploit browser exploits (ms10_002_aurora) Winamp exploit module	Adobe PDF exploits (utilprintf, pdf_embedded_exe)	Java exploit modules	browser_autopwn

★ Nouveaux dans ce chapitre : browser_autopwn

Chapitre 11 : Ingénierie sociale

Présente le Social-Engineer Toolkit (SET) pour automatiser les attaques ciblées sur l'humain : spear-phishing (création d'une pièce jointe malveillante, création de modèles, e-mail unique/en masse, configuration d'un auditeur), attaques Web de collecte d'informations d'identification (clonage d'une page de connexion), campagnes d'e-mails de masse et combinaison de techniques en attaques à plusieurs volets.

Techniques et points clés

- L'ingénierie sociale cible l'élément humain, qui « ne peut pas être corrigé ».
- SET peut également générer des clés USB malveillantes, des codes QR et des points d'accès malveillants (mentionnés, non détaillés).
- Une attaque à plusieurs volets pourrait récolter des informations d'identification ET exécuter simultanément une applet Java malveillante.

Outils utilisés dans ce chapitre

Social-Engineer Toolkit (SET)

★ Nouveaux dans ce chapitre : Social-Engineer Toolkit (SET)

Chapitre 12 : Contourner les applications antivirus

Corrige l'évasion de la détection AV des charges utiles Metasploit. Commence par les encodeurs msfvenom (qui se sont révélés largement inefficaces contre les antivirus modernes), puis explique le fonctionnement des moteurs antivirus (signatures, heuristiques) et teste les charges utiles par rapport à Microsoft Security Essentials et VirusTotal.

Couvre la création d'un modèle exécutable personnalisé et la compilation croisée avec MinGW, le chiffrement des charges utiles avec Hyperion et enfin l'évasion AV de manière plus robuste avec Veil-Evasion (injection VirtualAlloc + chiffrement).

Techniques et points clés

- Un simple codage msfvenom (par exemple, shikata_ga_nai seul) est généralement insuffisant contre l'AV moderne.
- VirusTotal est utilisé pour comparer les taux de détection sur de nombreux moteurs audiovisuels, avec une mise en garde en matière de confidentialité (les échantillons sont partagés avec les fournisseurs audiovisuels).
- Hyperion chiffre un exécutable existant au moment de l'exécution pour vaincre les signatures statiques.
- Veil-Evasion était, à l'époque, un générateur plus avancé produisant des charges utiles évasives AV.

Outils utilisés dans ce chapitre

msfvenom encoders Veil-Evasion	VirusTotal	MinGW cross-compiler	Hyperion

★ Nouveaux dans ce chapitre : Hyperion, Veil-Evasion

Chapitre 13 : Post-exploitation

Un large tour d’horizon de ce qu’il faut faire après avoir obtenu l’accès. Couvre l'utilisation principale de Meterpreter (upload, getuid, autres commandes), les scripts Meterpreter, les modules de post-exploitation Metasploit et l'API Railgun pour appeler les fonctions DLL Windows directement depuis Ruby.

Couvre l'élévation de privilèges locaux (getsystem, exploits locaux, contournement UAC, escalade Linux udev), la collecte d'informations locales (recherche de fichiers, keylogging, collecte d'informations d'identification, vérification de l'historique bash), le mouvement latéral (PSExec, pass-the-hash, SSHExec, emprunt d'identité de jeton/Incognito, capture SMB), le pivotement à travers des hôtes compromis (routes, analyse pivot, ProxyChains/Socks4a) et la persistance (ajout utilisateurs, script de persistance Metasploit, tâches cron).

Techniques et points clés

- « Le pentest commence véritablement après l'exploitation » : exploiter l'accès est aussi important que l'obtenir.
- Passer le hachage permet à un attaquant de s'authentifier avec un hachage NTLM capturé sans le pirater.
- Le pivotement (ajout de routes via une session) permet à Kali d'attaquer des hôtes non directement accessibles.
- Les mécanismes de persistance (nouvel utilisateur, tâche/cron planifiée, script de persistance Metasploit) maintiennent l'accès.

Outils utilisés dans ce chapitre

Meterpreter (core + scripts) PSExec ProxyChains / Socks4a	Metasploit post modules Pass-the-hash Metasploit persistence script	Railgun SSHExec	getsystem Incognito (token impersonation)

★ Nouveaux dans ce chapitre : Railgun, Incognito, ProxyChains

---

Chapitre 14 : Tests d'applications Web

Cible un exemple d’application Web délibérément vulnérable. Couvre l'interception/la modification des requêtes avec Burp Suite (Burp Proxy), le test et l'exploitation de l'injection SQL (manuelle et avec SQLMap) et l'injection XPath.

Couvre l'inclusion de fichiers locaux et distants (LFI/RFI), l'exécution de commandes du système d'exploitation via une entrée chaînée, le Cross-Site Scripting (XSS) — y compris l'exploitation d'une faille XSS reflétée avec le Browser Exploitation Framework (BeEF) — les concepts de Cross-Site Request Forgery (CSRF) et l'analyse automatisée avec w3af.

Techniques et points clés

- L'injection SQL dans l'exemple d'application permet l'extraction de données et même un shell de commande du système d'exploitation.
- Une deuxième faille d'injection dans la logique de connexion basée sur XML permet de contourner l'authentification.
- BeEF « accroche » le navigateur d'une victime via XSS, donnant à l'attaquant un canal de contrôle/prise d'attaque persistant.
- Pointe vers OWASP en tant que ressource canonique continue pour la sécurité des applications Web.

Outils utilisés dans ce chapitre

Burp Suite (Burp Proxy)	SQLMap	Browser Exploitation Framework (BeEF)	w3af

★ Nouveaux dans ce chapitre : Burp Suite, SQLMap, BeEF, w3af

Chapitre 15 : Attaques sans fil

Couvre l'évaluation de la sécurité Wi-Fi. Configure le mode surveillance et recherche les points d'accès, puis attaque chaque système de cryptage majeur : réseaux ouverts, WEP (expliquant ses faiblesses et piratant les clés avec Aircrack-ng), WPA/WPA2 (flux de négociation personnel et d'entreprise, capturant et craquant la négociation à 4 voies) et WPS (son défaut de conception et le forçage brutal du code PIN avec Bully).

Techniques et points clés

- Le système IV faible du WEP le rend craquable en injectant/collectant suffisamment de paquets.
- Le craquage WPA/WPA2-Personal nécessite de capturer la poignée de main à 4 voies et de l'attaquer par force brute/par dictionnaire.
- Le code PIN à 8 chiffres du WPS divisé en deux moitiés le rend brutalement forçable, quelle que soit la force du mot de passe Wi-Fi.
- Souligne que le sans fil est souvent une faiblesse du périmètre négligée.

Outils utilisés dans ce chapitre

Aircrack-ng suite	Airodump-ng / Aireplay-ng	Bully (WPS)

★ Nouveaux dans ce chapitre : Aircrack-ng, Bully

Partie IV — Développement d'exploits

Chapitre 16 : Un buffer overflow basé sur la pile sous Linux

Ouvre la partie IV avec la théorie de la mémoire/pile (registres, trames de pile, adresses de retour) avant de créer un exploit de buffer overflow Linux personnalisé minimal contre un programme C délibérément vulnérable en utilisant le strcpy non sécurisé

fonction.

Passe en revue le crash du programme, son débogage avec GDB, le contrôle d'EIP (le pointeur d'instruction) en débordant le tampon, le détournement de l'exécution pour rediriger vers une autre fonction du programme et une note sur l'endianité.

Techniques et points clés

- strcpy() sans vérification de limites est la cause classique des débordements de pile.
- GDB est utilisé pour inspecter les registres/pile et identifier exactement où EIP est écrasé.
- Le détournement d'EIP permet à l'attaquant de rediriger l'exécution n'importe où dans l'espace d'adressage du processus.
- Établit la technique fondamentale étendue aux logiciels du monde réel dans les chapitres 17 à 19.

Outils utilisés dans ce chapitre

GDB (GNU Debugger)	GCC (compiling the vulnerable target)

★ Nouveaux dans ce chapitre : GDB

Chapitre 17 : Un buffer overflow basé sur la pile dans Windows

Applique les concepts du Ch.16 à un programme Windows vulnérable réel et connu publiquement : War-FTP a un buffer overflow dans son champ Nom d'utilisateur. Trouve et vérifie le crash, puis localise précisément l'EIP à l'aide d'un modèle cyclique/De Bruijn et vérifie le décalage.

Au lieu de coder en dur une adresse mémoire, l'exploit trouve une instruction JMP ESP dans une DLL chargée pour rediriger de manière fiable l'exécution vers la mémoire contrôlée par l'attaquant, puis la remplit avec le shellcode généré par msfvenom pour faire apparaître un shell.

Techniques et points clés

- La génération de modèles cycliques (pattern_create/pattern_offset, Mona) trouve le décalage exact par rapport à EIP.
- JMP ESP est une technique de redirection classique et fiable qui évite les adresses codées en dur entre différentes versions de système.
- Le shellcode généré par msfvenom est déposé directement dans le tampon d'exploit spécialement conçu.

Outils utilisés dans ce chapitre

Immunity Debugger	Mona.py	msfvenom (shellcode generation)	War-FTP (target app)

Chapitre 18 : Écrasements du gestionnaire d'exceptions structurées

Couvre une deuxième technique majeure d'exploitation de Windows pour les plantages qui ne contrôlent pas proprement EIP mais écrasent la chaîne du gestionnaire d'exceptions structurées (SEH) - encore une fois en utilisant War-FTP.

Explique le passage du contrôle à SEH, la localisation de la chaîne d'attaque en mémoire, l'utilisation d'une séquence d'instructions POP POP RET à partir d'un module non compilé avec SafeSEH, l'utilisation d'un court saut pour atteindre le shellcode et le choix d'une payload fonctionnelle.

Techniques et points clés

- NSEH se situe de manière fiable à ESP+8 chaque fois qu'un crash basé sur SEH se produit – une étape clé pour les auteurs d'exploits.
- Les modules protégés par SafeSEH ne peuvent pas être utilisés pour le gadget POP POP RET ; les modules non protégés doivent être trouvés.
- Un court saut relie le pointeur SEH écrasé au shellcode réel dans le tampon.
- Notez que les mauvais caractères (par exemple, \xEB) forcent parfois à utiliser des techniques de saut alternatives.

Outils utilisés dans ce chapitre

Immunity Debugger	Mona.py	msfvenom

Chapitre 19 : Fuzzing, exploits de portage et modules Metasploit

Termine la partie IV avec des compétences pratiques en matière de flux de travail de développement d'exploits : fuzzing d'une cible (révision du code plus mutation d'entrée par force brute) pour découvrir un crash dans un serveur FTP trivial, puis portage d'un exploit public (trouver une nouvelle adresse de retour, remplacer le shellcode, édition pour l'environnement local).

Parcourez l'écriture d'un module Metasploit original en adaptant un exploit existant similaire et en portant le code d'exploit Python pour le débordement en mode de transport long 3Com TFTP. Se termine par un aperçu des techniques d'atténuation des exploits : cookies de pile, ASLR, DEP et signature de code obligatoire.

Techniques et points clés

- Fuzzing = alimenter systématiquement des entrées mal formées/surdimensionnées pour détecter les plantages sans la seule révision manuelle du code.
- Le portage des exploits publics (nouveaux décalages/adresses de retour/shellcode) adapte le code à l'environnement spécifique du laboratoire.
- L'écriture d'un module Metasploit contient un exploit fonctionnel destiné à être réutilisé par la communauté/d'autres pentesters.
- Les atténuations modernes (ASLR, DEP, cookies de pile, signature de code) sont présentées comme ce que les développeurs d'exploits du monde réel doivent contourner au-delà des exemples simplifiés du livre.

Outils utilisés dans ce chapitre

Custom Python fuzzer	GDB / Immunity Debugger	Metasploit module development framework

Partie V — Piratage mobile

Chapitre 20 : Utilisation du framework Smartphone Pentest

Clôture le livre avec la sécurité des appareils mobiles, construite autour de l'outil de l'auteur, le Smartphone Pentest Framework (SPF). Couvre les vecteurs d'attaque mobiles (SMS, NFC, codes QR), la configuration de SPF avec un émulateur Android, la création et le déploiement de l'application SPF Android et la connexion du serveur SPF à l'application.

Couvre les attaques à distance (connexion SSH par défaut sur les iPhones jailbreakés), les attaques mobiles côté client (un shell de navigateur WebKit, des codes de contrôle à distance USSD), la création d'agents SPF malveillants (porte dérobée d'APK légitimes) et la post-exploitation mobile - collecte d'informations, contrôle à distance, élévation de privilèges sur Android et attaques pivotantes à partir d'un téléphone compromis (par exemple, exécution de Nmap et d'un exploit War-FTP depuis l'appareil Android contre la cible Windows XP).

Techniques et points clés

- Les appareils mobiles élargissent la surface d'attaque via des vecteurs uniques : SMS, NFC, codes QR, codes USSD.
- Un téléphone compromis peut lui-même devenir un point pivot dans un réseau d’entreprise (risque BYOD).
- SPF reflète le modèle agent/gestionnaire de Metasploit, mais adapté aux smartphones.

- Termine le parcours du livre, de la « création d'un laboratoire » à l'évaluation d'une toute nouvelle classe d'appareils.

Outils utilisés dans ce chapitre

Smartphone Pentest Framework (SPF)	Android SDK / emulator	Nmap (from mobile pivot)	War-FTP exploit (reused via pivot)

★ Nouveaux dans ce chapitre : Smartphone Pentest Framework (SPF)

Index principal des outils (par première apparition)

Le tableau ci-dessous répertorie tous les principaux outils abordés dans le livre, dans l'ordre dans lequel ils sont introduits pour la première fois, avec le chapitre dans lequel ils apparaissent et leur objectif principal.

Outil	Chapitre(s)	Objectif
VMware	1	Plateforme de virtualisation hébergeant l'ensemble du laboratoire
Kali Linux	1	Distribution de tests d'intrusion basée sur Debian (plateforme d'attaque)
Immunity Debugger + Mona.py	1, 17, 18	Débogueur Windows utilisé pour le développement d'exploits
Netcat (nc)	2	Utilitaire de shell/écouteur/transfert de fichiers TCP/IP à usage général
Bash / Python / C	3	Scripts et programmation pour l'automatisation et les exploits
Metasploit Framework / Meterpreter	4, 8, 10, 13	Cadre d'exploitation de base et payload avancée
msfvenom	4, 8, 12, 17	Générateur de payload/shellcode autonome
theHarvester	5	Collecte automatisée d'OSINT (e-mails, hôtes)
Maltego	5	Visual OSINT / outil de cartographie des relations
Nmap (+ NSE)	5, 6, 20	Analyse des ports et vérification des vulnérabilités/services par script
Nessus	1, 6	Scanner de vulnérabilités automatisé
Nikto	6	Scanner de vulnérabilités du serveur Web
Wireshark	7	Capture de paquets et analyse du trafic
arpspoof / dnsspoof	7	Empoisonnement du cache ARP et DNS pour la redirection du trafic MITM
Ettercap	7	Interception automatisée MITM/SSL
SSLstrip	7	Rétrograde HTTPS en HTTP pour capturer les informations d'identification en texte brut
CeWL / Crunch	9	Génération de liste de mots personnalisée
Hydra	9	Forçage brutal de mots de passe en ligne
John the Ripper	9	Crackage du hachage de mot de passe hors ligne
Windows Credential Editor (WCE)	9	Extrait les informations d'identification en texte brut de la mémoire Windows
browser_autopwn	10	Module d'attaque de navigateur multi-exploit automatisé
Social-Engineer Toolkit (SET)	11	Automatise les attaques de phishing/d'ingénierie sociale
VirusTotal	12	Vérification de détection de logiciels malveillants/AV multimoteurs
Hyperion	12	Chiffrement des exécutables d'exécution pour l'évasion AV
Veil-Evasion	12	Générateur de payload AV-evasive avancé
Railgun / Incognito / ProxyChains	13	Post-exploitation : accès à l'API Windows, vol de jetons, pivotement
Burp Suite	14	Proxy Web pour intercepter/manipuler le trafic HTTP(S)
SQLMap	14	Exploitation automatisée des injections SQL
BeEF	14	Framework d'exploitation du navigateur (accrochage/contrôle XSS)
w3af	14	Scanner automatisé de vulnérabilités d'applications Web
Aircrack-ng / Bully	15	Wi-Fi (WEP/WPA/WPA2) et crackage des clés WPS

Outil	Chapitre(s)	Objectif
GDB	16	Débogueur Linux utilisé pour analyser les débordements de pile
Smartphone Pentest Framework (SPF)	20	Cadre de test d'intrusion des appareils mobiles (outil de l'auteur)

Notes finales

Ce livre (2014) est explicitement introductif et pratique : il privilégie un laboratoire guidé plutôt qu'une théorie exhaustive, et l'auteur note à plusieurs reprises que chaque sujet (test d'applications Web, évasion antivirus, post-exploitation, développement d'exploits, piratage mobile) "mérite son propre livre". L'annexe Ressources à la fin du livre répertorie les lectures complémentaires par chapitre (par exemple, Metasploit : le guide du testeur de pénétration, Hacking : l'art de l'exploitation, les ressources OWASP, les didacticiels d'écriture d'exploits Corelan).

Étant donné que le livre a maintenant plus de dix ans, plusieurs outils et détails spécifiques à la version sont datés (par exemple, BackTrack/anciennes versions de Kali, msfcli, CVE spécifiques comme MS08-067, Microsoft Security Essentials comme cible AV, détails WEP/WPA2). La méthodologie sous-jacente et la structure des phases d'un pentest restent d'actualité et constituent la valeur durable du livre.